# ネットワーク
# セキュリティ特論 II

# 授業概要

- コンピュータネットワーク上でのセキュリティ問題について，主にソフトウェア的側面から解説を行う。
- 特に，インターネット上でのセキュリティホールとその防御法について詳細に講義を行う。ネットワーク上でのセキュリティを向上させるには，攻撃者(クラッカー)の攻撃手段を熟知することが必要不可欠であるので，それらの点についても詳しく講義したい。
- また情報セキュリティスペシャリストの資格取得を目指して過去の試験の午後問題の演習を行う。

# スケジュール

- 今年から担当変更（森口先生ー＞早稲田）
- 今年度は昨年度を踏襲して行う予定
- ところにより変更する可能性有

- 10から14回は情報セキュリティマネジメント試験や情報処理安全確保支援士の過去問の予定

1　認証(認証と承認)
2　認証(パスワード方式)
3　認証(バイオメトリクス，　ＩＣカード)
4　認証(認証システム技術，　シングルサインオン)
5　暗号(暗号の基礎，　ＰＫＩ)
6　暗号(VPN，　IPSec，　SSL／TLS)
7　暗号(その他の暗号化通信技術)
8　暗号(無線ＬＡＮ)
9　ログ解析
10　問題演習１
11　問題演習２
12　問題演習３
13　問題演習４
14　問題演習５
15　まとめ

* 進捗状況により，内容が前後したり変更される場合がある.
* オンデマンドは第5回と第12回を予定しているが，変更になる可能性がある

# 評価

- 課題　40％
  - 受講した回の内容に関する課題を課し、次回までに提出し、理解度を評価する。
- レポート40％
  - 受講した回の内容に関するレポート課題により理解を深めさせ、その内容で評価する。
- その他　20％
  - 授業態度により、課題への取り組む姿勢を評価する。欠席は減点する。
  - 授業回数の3分の2以上出席した者を評価対象とする。遅刻は1/2欠席と換算する。
  - 試験は行わない。そのかわりに、レポート課題は必ず提出すること。
- こちらも変更する可能性有

# 認証(認証と承認)

# アクセス制御

- 情報や情報システムの機密性を確保するため，情報資産の閲覧，操作などを正当な権限が持つモノだけが行えるようにする技術

- 正当な権限を持つモノであることを確認するための技術が認証

- 認証を通過したモノに権限（許可）を与える（ことを承認する）
  - 代表的な権限は読み(read, r), 書き(write, x), 実行(execute, x)

# アクセス制御の種類

- 場所による種類
  - 物理環境におけるアクセス制御
    - 機器の設置してある場所に近寄れなくする
    - 入退室管理システム，施錠
  - ネットワーク環境におけるアクセス制御
    - 異なるネットワークセグメント間でのパケットやフレームの通過，拒否をコントロール
    - ブリッジ，ルータ，ファイアウォール，ゲートウェイなど
  - ホストやアプリケーションシステムに対するアクセス制御
    - ユーザの識別認証を行ってログインを制御
  - システムリソースに対するアクセス制御
    - ディレクトリ，ファイル，プログラム，デバイスなどの読み取り，書き込み，削除，実行などの可否を制御

# アクセス制御の種類

- 任意アクセス制御
  - Discretionary Access Control, DAC
  - 所有者がアクセス権を設定する方式
  - 機密保持には向かない
- 強制アクセス制御
  - Mandatory Access Control, MAC
  - 保護対象と操作する者にセキュリティレベルを設定し，その間の関係により強制的にアクセス権を設定する方式
  - 所有者であってもアクセス権を設定できない

# アクセス制御の種類

- ロールベースアクセス制御
  - Role-Based Access Control, RBAC
  - 業務上の役割(ロール)毎にアクセス権限を設定する方式
  - すべてのユーザに複数のロールが与えられる
- MLS(multi-level security)
  - 保護対象の情報とユーザを機密レベルにより階層分けしてラベルを付し，ユーザの機密レベルが情報の機密レベルより，上位，同位，下位に対して行える操作を規定することでアクセス制御を行う.

# 認証

- 相手が正しいモノであること確認する技術
  - 確認することを検証という
- 正しいモノによる分類
  - ユーザ認証：対象人が正規のユーザあることを確認
  - クライアント認証：システムやネットワークにアクセスしている端末（クライアント）が正規の物であることを確認
  - メッセージ認証：メッセージ（情報）が正しいことを確認

# クライアント認証

- システムやネットワークにアクセスしている端末（クライアント）が正規の物であることを確認

- SSL/TLSの中で行われているので，知らずに利用していることが多い
  - SSL/TLSは第6回で行う予定
- MACアドレスの確認
- クライアント証明書による確認

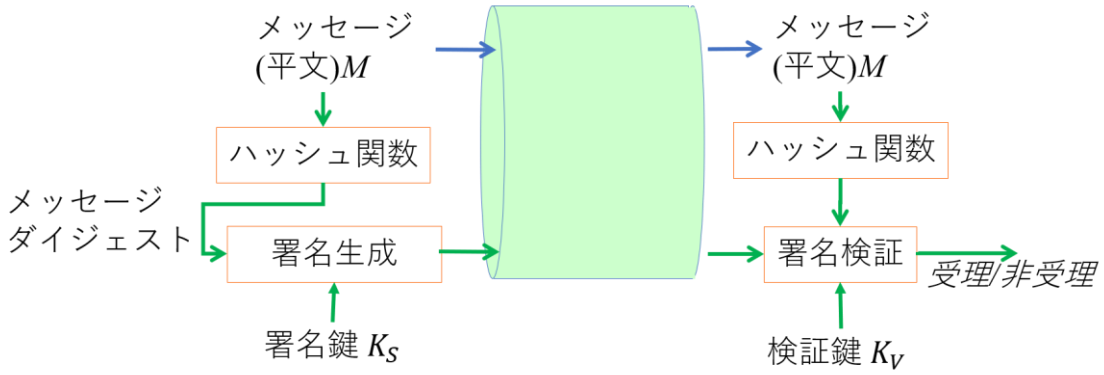
# メッセージ認証

- メッセージの改ざんが行われていないかの確認を行う
- ディジタル署名とMAC(Message Authentication Code)が使われる

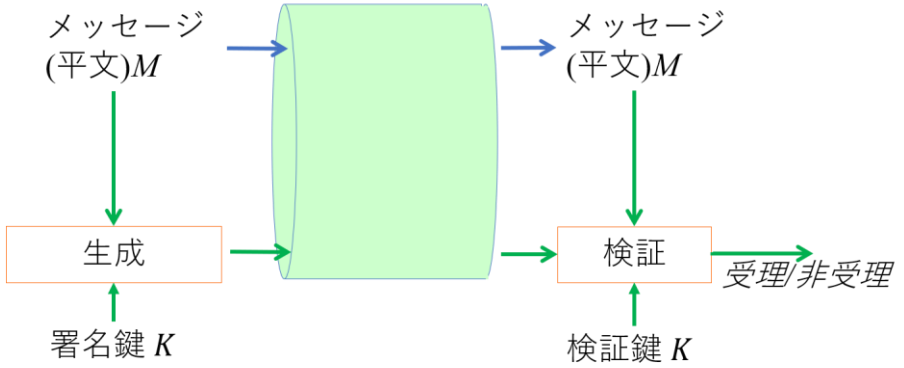
| | ディジタル署名 | MAC |
|---|---|---|
| ベース | 公開鍵暗号ベース | 共通鍵暗号ベース |
| 鍵 | 秘密鍵で署名し，<br>公開鍵で検証 | 共通（秘密）鍵で生成と検証 |
| 検証 | 誰でもできる | 秘密鍵を知っている人だけ |
| 速度 | 遅い | 速い |
| 否認防止 | ある（作るには秘密鍵が必要で，秘密鍵を知っているのはその人だけ） | ない（同じ鍵を持っている人のどちらが作ったか分からない） |

# ディジタル署名とMAC

ディジタル署名（添付型）




メッセージ認証コード（MAC）




注意点：ハッシュ関数を使ってメッセージダイジェストの作成は必須ではない
MACには生成に鍵付きハッシュ関数を使った方式（HMAC）もある

ディジタル署名について：通常，署名生成＝復号，署名検証＝暗号化ではない．ディジタル署名は暗号の逆操作ではないので注意

# ユーザ認証

- 相手が正しい人か確認する

- 何を使って確認するかにより大きく3つに分かれる
  - 知識：ある情報を知っていることで確認する
    - パスワード認証，暗証番号
  - 物：ある物を持っていることで確認する
    - 印鑑，ICカード，ディジタル証明書
  - 身に備えているもの（バイオメトリクス認証）
    - 指紋，虹彩，筆跡

# 多要素認証，二段階認証

- 多要素認証
  - 確認する要素を複数組み合わせて認証する方式
  - 例：キャッシュカード（物）と暗証番号（知識）
- 二段階認証
  - 別の方法で認証を繰り返す方式
  - IDとパスワードを入力した後，端末に送られてきた情報を入力する
    - 知識と物の多要素認証でもあるｆ

# リスクベース認証

- 通常と異なる環境や状況でのログイン試行に対して，通常の認証のほかに追加で確認をとる方式
  - 通常と異なる場合リスクがあると認識する

- 環境や状況の確認方法
  - 機器やOS，ブラウザ，IPアドレス，アクセス時間等のシステム情報をバックグランドでチェック
  - 通常はユーザ側では追加で何かを行う必要はない
    - リスクがあると認定されると追加操作が必要

# ユーザ認証とクライアント認証

- ちょっと前まではクライアント認証はあまり意識されていなかった
  - 基本的に組織から与えられた据え置きの端末からのアクセスが主であったので，ユーザ認証で事足りた.
  - モバイル端末，ノートPCからのアクセス，私物のPCやスマホの業務利用（Bring Your Own Device, BYOD）が増えた結果，ユーザ認証だけでは足りなくなった.
  - 今は両方を行うのが主流になっている.

# 次回

- パスワード認証